

Cybersecurity Risks and Threats

Week 02 · Booklet 2 · Study Booklet

Course 01_Cyber_Security (CS502)

Instructor Asst. Prof. Dr. Huda Lafta Majeed

Primary source Robin Sharp, *Introduction to Cybersecurity: A Multidisciplinary Challenge*, Springer, Cham, 2023 — Chapter 3 “Risk”, pp. 37–56

DOI 10.1007/978-3-031-41463-3_3

Built from the original textbook and from the doctor's own marking of the delivered booklet. Every section is tagged with the source it came from. Where the material is known to be inaccurate, the correct fact is stated alongside.

Figure 3.1 photograph: Terry Goss, Wikimedia Commons, *White_shark.jpg*, CC-BY 2.5 Generic.

Contents

1	How to use this booklet	3
2	What the doctor marked as important	4
3	RISK, THE CORE IDEA	
3.1	What is risk? Objective and subjective	6
3.2	Threat, vulnerability and damage	6
3.3	Basic risk: $S = F \times K$, and the risk matrix	7
3.4	Countermeasures and residual risk: $R = S / M$	9
3.5	The three-point scale	11
3.6	Threats in IT systems — the four groups	11
3.7	Countermeasures matched to threats	12
3.8	The five steps for dealing with damage	13
3.9	Risk management and the five strategies	14
3.10	Systematic security analysis — five frameworks	15
3.11	ISO/IEC 27002 and the ISO 27000 series	16
3.12	OCTAVE	17
3.13	PDCA	18
3.14	Worked examples	20
4	PHYSICAL SECURITY AND AUTHENTICATION	
4.1	Security policy and access control	22
4.2	Locks, deadbolts and cipher locks	22
4.3	Gates and control relays	23
4.4	Authentication systems and the four factors	24
4.5	Authentication technologies	25
4.6	Remote monitoring and automated access control	26
4.7	The NIST material	27
4.8	Cyber risk assessment and management	28
5	Exam traps and formula card	30

6	Glossary	32
7	Sources and verification notes	33

Page numbers refer to the printed page shown at the foot of each page.

1 How to use this booklet

This booklet merges everything the Week 02 material contains into one ordered document, with the original figures, and it marks what the doctor treated as examinable.

Two sources, clearly separated

The booklet the doctor distributed is a **compilation of two different books**. That was verified by searching the primary source end to end. It matters, because the two parts behave differently in the exam.

Part	Where it comes from	How to treat it
Sections 3.1–3.14 Risk theory	Sharp, <i>Introduction to Cybersecurity</i> , Chapter 3 “Risk”, pp. 37–56	Complete and verified against the original. Every figure in this booklet is from here.
Sections 4.1–4.8 Physical security, authentication, NIST	An unidentified second source . None of this text appears in Sharp at all.	Use the wording as given. One term in it is wrong — see §4.4.

The doctor's exam method

The quiz is **written / essay**, roughly ten minutes, at the start of the lecture. The stakes are soft — it is a reading check.

ANSWER SHAPE

- If the question gives you numbers — apply the formula. This booklet has two: $S = F \times K$ and $R = S / M$.
- If it gives you no numbers (an analytical scenario) — answer as **step** → **CIA pillar** → **(techniques in brackets)**.

How the marking in this booklet works

Marker	Meaning
Marked YELLOW in the doctor's copy	A countable list to memorise — the count first, then the items.
Marked RED in the doctor's copy	Something to be able to explain out loud.

Not marked at all	Still readable material, but not flagged as examinable.
Corrected badge	The book itself is wrong here. The exam answer and the correct fact are both given.

ONE RULE FOR THE WHOLE BOOKLET

Where the material is inaccurate, **answer in the doctor's vocabulary — she marks it — but know the correct fact.** Writing the correction alongside, in brackets, shows mastery instead of contradicting her.

2 What the doctor marked as important

The delivered Word file carries the doctor's own highlighting. Extracting it mechanically gives an objective map of the exam scope — it is not an interpretation.

Yellow highlight — memorise these lists

Marked text	What it is
Risk avoidance · Risk reduction · Risk retention · Risk transfer · Risk sharing	The five mitigation strategies (§3.9)
COBIT · COSO · FAIR · OCTAVE	Four of the five analysis frameworks (§3.10)
"...the latest version of ISO/IEC 27002 from 2022... within 14 categories "	The ISO number 14 (§3.11) — corrected in this booklet
"...threats and vulnerabilities in three phases "	OCTAVE's phase count (§3.12)

Red highlight — be able to explain these

Marked text	What it is
Build up asset-based threat profiles · Identify vulnerabilities in the infrastructure · Develop a security strategy and plans	The three OCTAVE phases (§3.12)
Plan · Do · Check · Act	The four PDCA elements (§3.13)
Locks and Keys · Locking Deadbolts · Cipher Locks · Control Gates · Authentication Systems	The physical security controls (§4.2–4.4)
Knowledge · Possession · Inheritance · Location	The four authentication factors (§4.4)

Coloured text — the taxonomies

Not highlighted, but set in colour, which marks the classification schemes:

- The **four threat groups** — hardware, software, data, liveware (§3.6)

- The **countermeasure-to-threat matching** (§3.7)
- The **equation letters S, F, K** — the only equation symbols she coloured (§3.3)

WHAT SHE DID NOT MARK

The two NIST blocks — *“Develop a risk-management program”* and *“Use NIST security controls”* — carry no marking at all. The student's own verdict was that they are **not important**. Recorded in §4.7 so you can read them once and move on.

3.1 What is risk? Objective and subjective

DEFINITION — SHARP, P. 38

Risk, in its **technical sense**, is the **quantitative probability** that an error situation occurs and gives rise to damage. In IT security, **damage** is synonymous with a breach of the security policy.

Objective risk

That definition is **objective** — it is a property of the system, not of anyone's opinion. It must not be confused with subjective risk.

Subjective risk

Subjective risk also takes **human factors** into account — public attitudes, trust, and personality. The same situation can carry a very different perceived risk from its actual risk.

EVIDENCE — THE DANISH SURVEY, SHARP P. 56

In a 2009 Danish investigation, respondents judged whether various events counted as security breaches:

- **Almost 100%** said it was a breach if other people extracted personal data from their computer over the net.
- **Only about a quarter** thought **theft of their computer** was a breach — even though theft is **more common** than hacking and gives the thief easy access to everything on the machine.

People's perception of risk for those two event types was evidently very different from the actual risk. That gap is exactly what "subjective risk" names.

EXAM-READY PAIR

Objective risk — the technical, quantitative definition. **Subjective risk** — the same situation as people perceive it, shaped by attitudes, trust and personality.

3.2 Threat, vulnerability and damage

Damage does not appear on its own. It requires a **threat** acting on a **vulnerability**.

THE CAUSAL CHAIN

Damage occurs when a **threat** is realised against some weakness in the system. A weakness which can be exploited to damage the system is known as a **vulnerability**.



Figure 3.1 — The threat is the **shark**; the vulnerability is a **welding fault in the cage**.

Photo: Terry Goss, Wikimedia Commons, CC-BY 2.5 Generic. (Sharp, p. 38)

The metaphor is worth holding on to, because it separates two things students routinely merge: the **shark exists** whether or not the cage is faulty, and the **welding fault exists** whether or not a shark is nearby. **Neither one is damage**. Damage needs both.

CONSEQUENCES OF THE DISTINCTION

- A **threat** is not a vulnerability.
- A **vulnerability** is not a threat.
- Neither is, by itself, **risk** — risk is the quantified combination (§3.3).

EXAM TRAP

If a question describes a weakness with no actor, the answer is **vulnerability**. If it describes an actor with no weakness, the answer is **threat**. Only when both are present, and quantified, does the question become about **risk**.

3.3 Basic risk: $S = F \times K$, and the risk matrix

$$S = F \times K$$

Symbol	Meaning — Sharp, p. 38
S	The basic risk of a threat
F	The frequency of attempts to exploit the vulnerability
K	The consequences of a successful attempt

Note: the doctor coloured **S**, **F** and **K** red in her copy. These three letters are hers.

Why it is a multiplication, not a sum

This is worth being able to argue, because it is a likely essay question.

- **By multiplication:** if either factor is near zero, the product collapses. A nuisance that happens constantly but harms nothing is not a catastrophe; a catastrophe that never happens is not a threat either. **Both factors must matter** — and multiplication enforces exactly that.
- **By addition:** a very large frequency could **compensate** for zero consequences and produce a large “risk”. That is nonsense — an event with no consequence cannot be a risk.

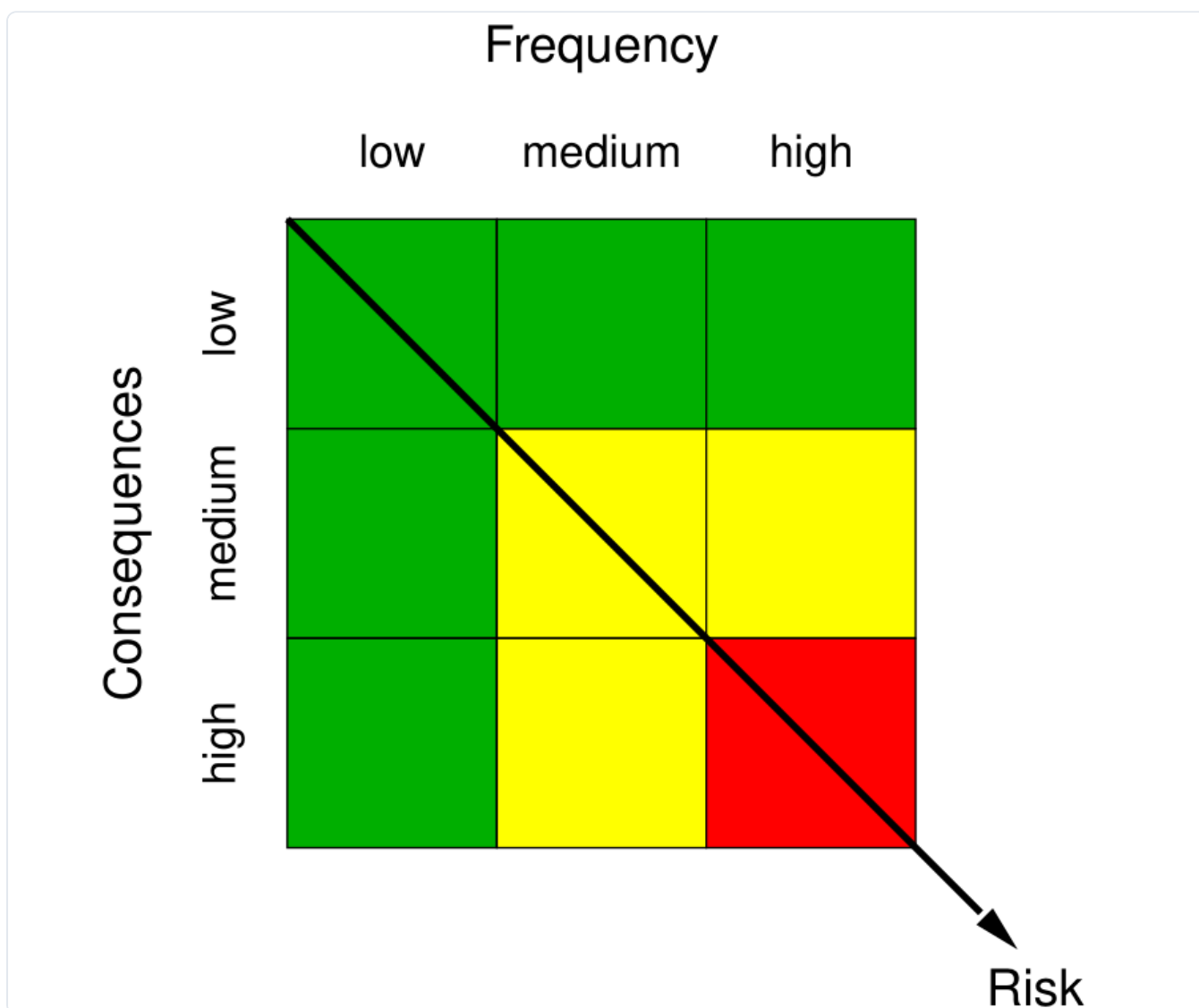


Figure 3.2 — The risk matrix. The individual threats are placed in the square matching their frequency and consequences. (Sharp, p. 38)

Reading the matrix

Consequences ↓ / Frequency →	low	medium	high
low	green	green	green
medium	green	yellow	yellow
high	green	yellow	red

The diagonal arrow labelled **Risk** shows risk rising from the top-left corner to the bottom-right corner.

THE RULE TO REMEMBER

Red appears in exactly one cell: high frequency AND high consequences. This is what the book states in words — *“This arises when the consequences of a successful attack are high and the frequency of attempts to exploit the vulnerability is also high.”*

3.4 Countermeasures and residual risk: $R = S / M$

Risk is reduced by introducing **countermeasures**, also called **controls**, which must protect against the relevant threat. What is left is the **residual risk**.

$$R = S / M$$

Symbol	Meaning — Sharp, p. 39
R	The residual risk — the reduced risk
S	The risk of the threat, from §3.3
M	The level of countermeasures — and this is the part to be precise about

WHAT M COVERS — QUOTE THIS IN THE EXAM

M covers both the number of countermeasures — there can be several things which affect the risk for particular types of attack — and their effectiveness.

So M is not simply “how many countermeasures”. Ten weak measures are not the same as one strong one. M is a **combined protective factor**: count **and** quality.

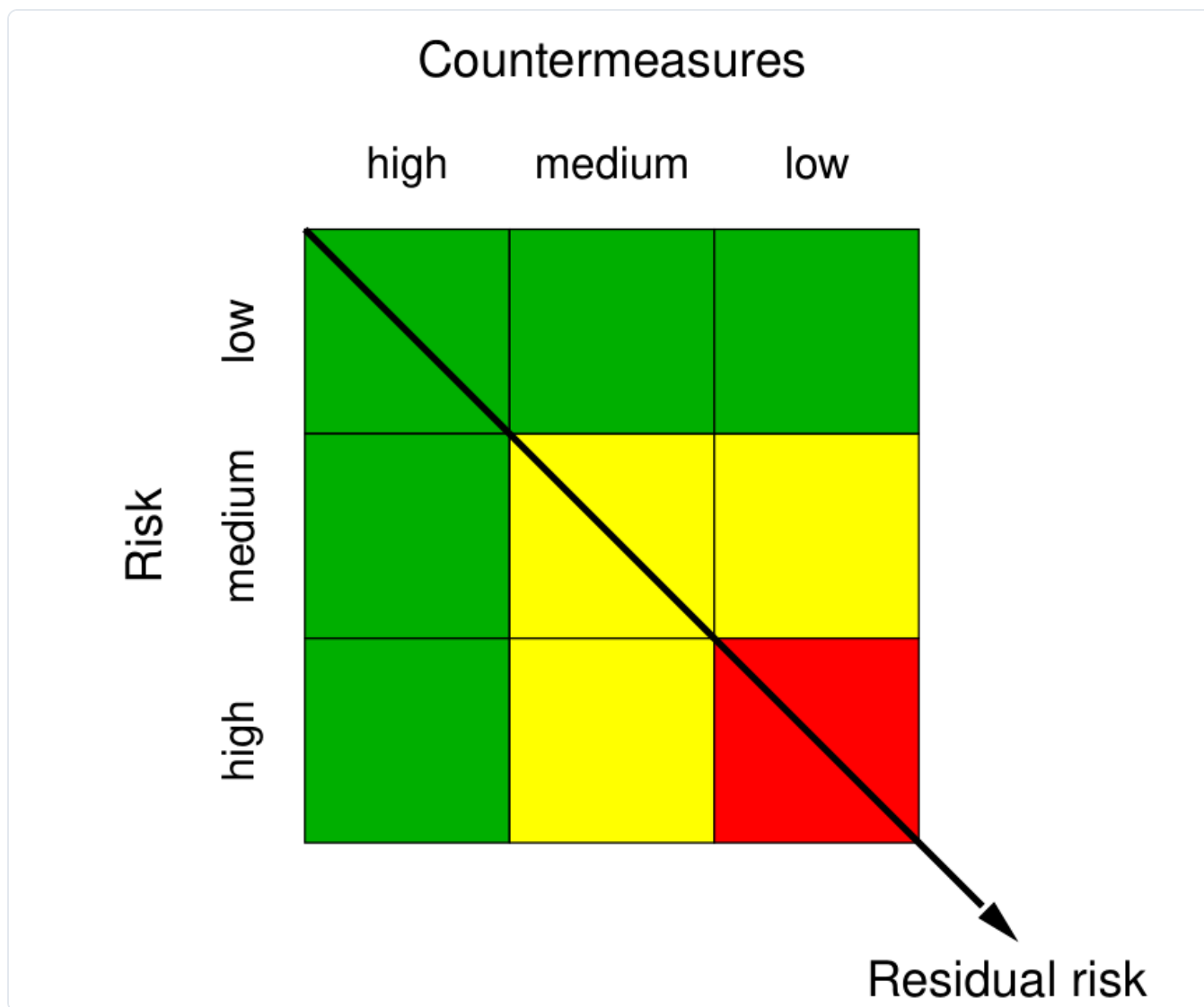


Figure 3.3 — The residual risk matrix. Note the countermeasures axis is **reversed**: high on the left. (Sharp, p. 39)

Reading the matrix

Risk ↓ / Countermeasures →	high	medium	low
low	green	green	green
medium	green	yellow	yellow
high	green	yellow	red

Diagonal arrow labelled **Residual risk**. Red appears in exactly one cell: high risk AND low countermeasures.

THE TWO-STAGE MODEL — DO NOT MIX THE MATRICES UP

Matrix	Axes	Red corner
Risk matrix (Fig. 3.2)	frequency × consequences	high and high
Residual risk matrix (Fig. 3.3)	risk ÷ countermeasures	high risk, low countermeasures

The relationship: the first equation **feeds** the second. **S** is computed once from frequency and consequences, then used as the input to **R = S / M**. They are two stages of one pipeline, not two alternatives.

3.5 The three-point scale

SHARP, P. 39 — QUOTED

"In the two figures, 3.2 and 3.3, we have here used a 3-point scale (low, medium, high) for all quantities (frequency, consequences, risk, countermeasures, residual risk). This is a somewhat arbitrary but often used convention."

The book gives its reason for staying coarse, and it is a good one:

"Even if one can argue for a finer division of the scale, the uncertainty in estimating these variables is in practice large, and a finer division is therefore (at least in the first instance) more or less meaningless."

Why the scale matters for the equations

The book's own worked examples print the arithmetic like this:

medium × high = medium

That is not arithmetic multiplication — it is a **combination on an ordinal scale**, read back onto the same three levels. So **×** and **÷** in this material are shorthand for the colour tables, not numbers to calculate.

EXAM TRAP

If a question gives you low / medium / high, **read the answer off Figure 3.2 or 3.3**. Do not try to multiply or divide the words as if they were numbers.

Consequences are the hardest quantity to place

The book notes that consequences can be particularly difficult to put on a scale, because the impact of an attack may involve several kinds of element:

- Financial losses due to increased costs or loss of income
- Loss of reputation — for example failure to provide agreed services or meet delivery dates
- Penalties for failing to fulfil regulatory requirements
- Compensation to employees for failing to meet obligations of employment

Or combinations of these. And what counts as **low, medium or high** naturally depends on **the size and purpose of the IT system** — a consequence that is severe for a small clinic may be minor for a bank.

3.6 Threats in IT systems — the four groups

Many IT users believe the only threat is an attacker hacking in. In reality the threat pattern is far more varied. The book separates it into **four groups**.

1. Hardware-related threats

Threats which **physically** affect the computer itself or the infrastructure it depends on.

- Harmful surroundings
- Natural disasters such as storms
- Physical attacks on the computer, such as theft
- Faults in the infrastructure

2. Software-related threats

Threats affecting the **software installed** in the computer — applications and the operating system — or arising from poorly designed or wilfully malicious programs from outside.

- Unauthorised modification or deletion of software
- Wilfully malicious programs — **malware**: viruses, worms, trojan horses, logic bombs
- Poorly designed programs which contain vulnerabilities
- Incorrect or out-of-date software versions
- Theft or unauthorised copying of software

3. Data-related threats

Threats which can lead to **unauthorised processing, including storage, of data** in any way.

- Unwanted storage, modification, disclosure or deletion of data
- **Inference** — collecting accessible data from which it is possible to **deduce confidential information that is not directly accessible**
- **Masquerading** — pretending to be someone else — and unauthorised access

4. Liveware-related threats

Threats related to **human error among the computer's users**.

- Social engineering, phishing
- IT fraud, forgery and other forms of criminality, now carried out with the help of computers

THE DISTINCTION THAT EARNS MARKS

Inference is not direct theft of confidential data. It is collecting data that *is* accessible and deducing from it information that is *not* directly accessible. If a question describes a chain of reasoning from public or low-privilege data to a secret, the answer is **inference**, not unauthorised access.

3.7 Countermeasures matched to threats

A threat is blocked by controlling a vulnerability with suitable countermeasures — and the countermeasure **must be adapted to the type of threat**. The book gives six pairings.

Threat	Countermeasure
Attackers outside the system, attacking through the Internet	Firewalls in the network, to prevent traffic from the attacker reaching the target
Malware	Antivirus programs and other so-called security programs
Vandalism, theft and other physical damage to the equipment	Place the equipment in a secure room
Unauthorised modification or deletion of data or software	Take regular backup copies
Unauthorised access to data	Use encryption or access control
Personnel and ordinary authorised users	Check personnel and introduce suitable training

EXAM TRAP

The last row is the one that catches people. The threat here is **the organisation's own authorised users** — not an outsider. And the countermeasure is **administrative, not technical**: vetting and training. If a question describes an insider threat and the options are all technical controls, the administrative answer is the one you want.

The general point

There is no single countermeasure that covers everything. The matching is the content: **each threat has its own appropriate control**, and choosing the control is the security work.

3.8 The five steps for dealing with damage

RECOVERED CONTENT

This list is in the original book (Sharp, p. 42). **It was missing from the Word booklet the doctor distributed.** If you remembered a five-step list that was not in the file, this is it.

More generally, the book says, one can deal with damaging events in five ways:

#	Step	What it means
1	Preventing them	Block attacks, or remove or reduce the vulnerability
2	Complicating them	Make the attack more difficult to perform
3	Diverting them	Make other targets more attractive
4	Detecting them	When they occur, or later

5	Reestablishing status	After them
---	-----------------------	------------

THE SPLIT WORTH MEMORISING — THE BOOK'S OWN WORDING

*"Notice that some of them (1, 2 and 3) are **proactive** steps, which reduce the risk before the damage takes place, while others (4 and 5) are **reactive** steps which are taken when the damage has in fact occurred."*

Proactive: 1, 2, 3. Reactive: 4, 5. Ways of dealing with damage can naturally be combined.

DO NOT CONFUSE THE TWO FIVE-ITEM LISTS

- **This list (§3.8)** — how to **deal with damage**: preventing, complicating, diverting, detecting, reestablishing.
- **The next list (§3.9)** — the five **risk mitigation strategies**: avoidance, reduction, retention, transfer, sharing.

Both have five items. They are different lists, and a question about one will offer items from the other as distractors.

3.9 Risk management and the five strategies

DEFINITION — SHARP, P. 42

Risk management deals with **all the activities which are related to evaluating and reducing risks**. The part whose aim is to reduce risk to an **acceptable level** is often called **risk mitigation**.

Note the containment: risk mitigation is a *part of* risk management, not a synonym for it. The umbrella is evaluation **and** reduction; the subset is reduction to an acceptable level.

The five strategies — in this order

MARKED YELLOW BY THE DOCTOR — LEARN THE ORDER

#	Strategy	What it means	The book's example
1	Risk avoidance	Keep the target system away from given risks	Forbid risky behaviour such as use of WiFi
2	Risk reduction	Take proactive steps to prevent losses occurring, or to reduce the extent of the loss	Make use of backups, encryption and so on
3	Risk retention	Allow a certain, agreed amount of residual risk	Use reliable, but not redundant, communication equipment
4	Risk transfer	Transfer the risk to others	Set up a contract for outsourcing

5	Risk sharing	Agree with other parties to deal with risks jointly	Agree on common facilities or mutual insurance
---	--------------	---	--

TRANSFER VERSUS SHARING

Transfer hands the risk to someone else — you are no longer carrying it. **Sharing** keeps you in the risk but splits it with others. Outsourcing is transfer; mutual insurance or shared facilities is sharing.

The balance every choice must strike

Whichever strategy you choose, the book says risk management must balance **three factors**:

Factor	The question it answers
Security	How well is the IT system protected against unwanted events?
Functionality	How well does the IT system perform its intended functions?
Usability	How easy is it for users to make use of the system?

THE BOOK'S WARNING — WORTH QUOTING

*"This last factor is unfortunately often forgotten by system designers... **If security measures do not give a usable system, users will find ways to avoid them!**"*

3.10 Systematic security analysis — five frameworks

To develop a secure system it is an advantage to use a systematic method. Over the years a number of procedures have been developed for security analysis of IT systems.

Framework	Full name	What it offers
COBIT marked yellow	Control Objectives for Information and related Technology	Objectives for measures which can be used to manage risk
COSO marked yellow	Committee of Sponsoring Organizations	A detailed description of the internal processes a company must follow to reach a suitably low risk
FAIR marked yellow	Factor Analysis of Information Risk	A taxonomy of risk factors, a standard for naming risk-related quantities, and a model for calculating risk
ISO/IEC 27002	International standard	A checklist of what must be considered to achieve a secure system (§3.11)

OCTAVE marked yellow	Operationally Critical Threat, Asset and Vulnerability Evaluation	The process of analysing threats and the corresponding risks, and of finding suitable countermeasures (§3.12)
--------------------------------	---	--

HOW TO TELL THEM APART IN ONE LINE EACH

- **COBIT** — objectives for managing risk.
- **COSO** — internal processes inside the company.
- **FAIR** — the only one with a **calculation model**; also a naming standard.
- **ISO/IEC 27002** — a **checklist**.
- **OCTAVE** — a **process**.

The book notes that the last two are not alternatives: **they supplement one another**, because risk analysis is an important element of the ISO/IEC 27002 checklist.

3.11 ISO/IEC 27002 and the ISO 27000 series

SHARP, P. 43

ISO/IEC 27002 is part of a series developed **jointly by ISO and IEC** — the International Organization for Standardization and the International Electrotechnical Commission. The series currently consists of **44 complete or planned standards**, covering information security in general and in specific areas such as **finance, energy supply, collection of digital evidence and cloud computing**.

The series, as the book tabulates it

The book carries a table the Word booklet dropped. It is worth having, because the two numbers that get confused are both in it.

Standard	Topic
ISO/IEC 27000	Information security management systems — Overview and vocabulary
ISO/IEC 27001	Information security management systems — Requirements
ISO/IEC 27002	Code of practice for information security controls
ISO/IEC 27003	ISMS implementation guidance
ISO/IEC 27005	Information security risk management
ISO/IEC 27017	Code of practice for information security controls for cloud services

27001 VERSUS 27002 — THE DISTINCTION THE BOOKLET LOST

27001 = Requirements. It is the standard an organisation is **certified against**.

27002 = Code of practice. It is the **guidance** — the checklist of controls.

They are different documents. If a question asks which one you are audited against, it is 27001.

The fourteen categories — and the correction

CORRECTED — THE BOOK IS WRONG HERE, AND THE DOCTOR HIGHLIGHTED THIS LINE YELLOW

The material says: “The latest version of ISO/IEC 27002 from **2022** describes targets for what has to be done within **14 categories**” — and then lists fourteen items.

The list is real, but the **label is wrong**:

Edition	Actual structure
ISO/IEC 27002:2013	114 controls in 14 clauses — and these are the fourteen items listed
ISO/IEC 27002:2022	93 controls in 4 themes: Organisational · People · Physical · Technological

In the exam: write **14**, because that is what she marked. If there is room, add “(the 2013 structure; the 2022 revision reorganised into 4 themes and 93 controls)”. That shows mastery rather than contradicting her.

The fourteen categories, in order

#	Category	#	Category
1	Information security policies	8	Operation security
2	Organization of information security	9	Communication security
3	Human resource security	10	System acquisition, development and maintenance
4	Asset management	11	Supplier relationships
5	Access control	12	Information security incident management
6	Cryptography	13	Information security aspects of business continuity management
7	Physical and environmental security	14	Compliance with legal and contractual requirements

The list is logically ordered — policies → organisation → people → assets → access → cryptography → physical → operations → communications → development → suppliers → incidents → continuity → compliance. Learn the logic and the fourteen fall out in sequence.

3.12 OCTAVE

WHAT IT IS

OCTAVE — Operationally Critical Threat, Asset and Vulnerability Evaluation — is a method for risk analysis, developed at **Carnegie Mellon University** for the **US Department of Defense**, by the **CERT** Coordination Center at the university's Software Engineering Institute.

The three phases

MARKED RED BY THE DOCTOR — BE ABLE TO STATE THESE

Phase	Name	What happens
1	Build asset-based threat profiles	An organisational evaluation. Determine what matters to the organisation, select the critical assets, and identify threats to each — creating a threat profile per asset
2	Identify vulnerabilities in the infrastructure	Examine network access paths and how far each class of component resists attack
3	Develop a security strategy and plans	Identify risks to critical assets, build a protection strategy and mitigation plans

The variants

The book lists **four**:

1. **OCTAVE** — the original method
2. **OCTAVE-S** — a simplified version for **small enterprises with limited resources**
3. **OCTAVE ALLEGRO** — an expanded version for enterprises with an **advanced IT structure**
4. **OCTAVE FORTE** — listed in the book with no description

ON THE FOURTH VARIANT — A NOTE, NOT A CORRECTION

Public OCTAVE documentation names only **three** methodologies: OCTAVE, OCTAVE-S and OCTAVE Allegro. **No source outside this book names an “OCTAVE Forte”**, and the book itself gives no description — the sentence is garbled in the original. So the fourth variant is the **book's**, not the doctor's invention, and she is reproducing it faithfully.

In the exam: the book says four, so write four. The three that matter for explaining are OCTAVE, OCTAVE-S and Allegro.

Also worth knowing, though not in this chapter: **OCTAVE Allegro** runs on **eight steps in four phases**, not three. The three-phase structure above belongs to the original OCTAVE method.

3.13 PDCA

WHY PDCA AT ALL — SHARP, P. 53

Risk management should not be a one-time activity. The risk profile changes with time, as new forms of attack are developed or known threats appear more often. The situation must be **re-evaluated at regular intervals**. Risk management therefore most often takes the form of a **PDCA process**.

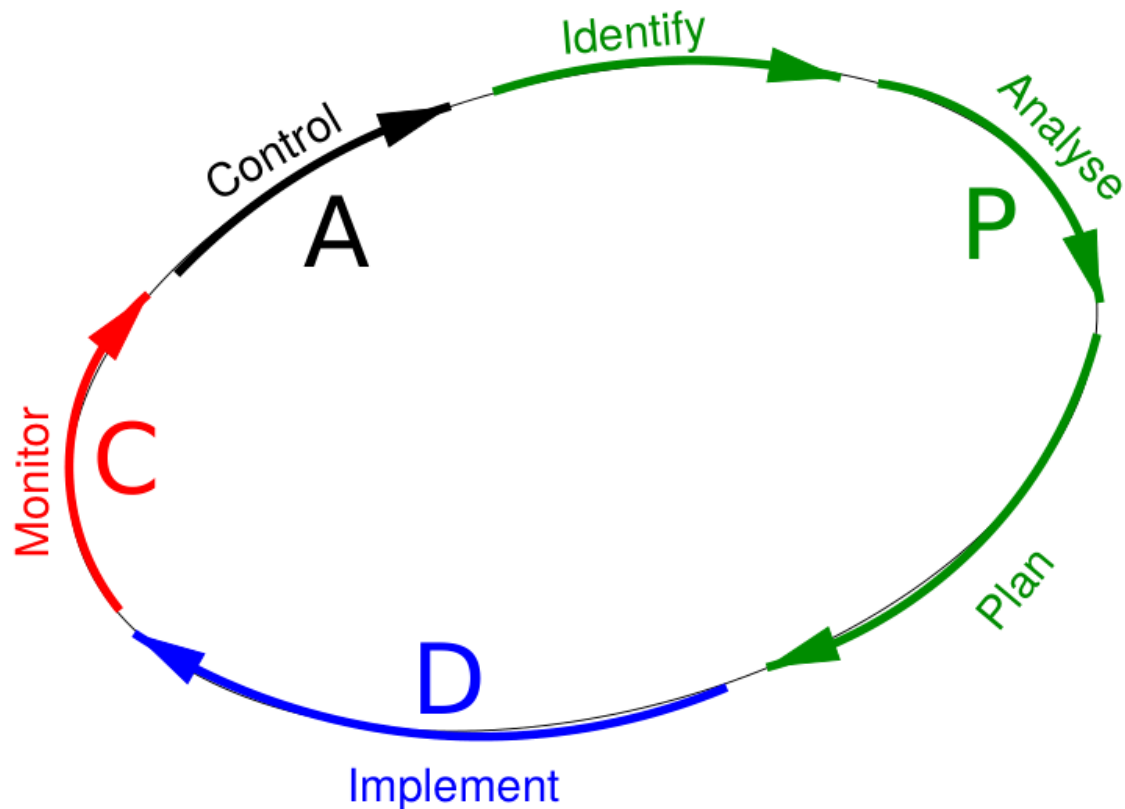


Figure 3.11 — Schematic view of a PDCA process. (Sharp, p. 54)

The four phases

MARKED RED BY THE DOCTOR — THE ACRONYM AND THE ELEMENTS

Phase	What happens in risk management
Plan	Threats are identified, risks are analysed, and countermeasures are planned
Do	Countermeasures or other forms of risk management are implemented
Check	The implemented solution is monitored, to check that the desired level of security is maintained
Act	The solution is adjusted so that it continues to give the desired security level, or a decision is taken to carry out a completely new Plan phase

THE POINT MOST STUDENTS MISS

Act does not close the process — it restarts it. It ends either in an adjustment or in a decision to begin a completely new Plan phase. PDCA is a **cycle**, not a straight line: the four phases are repeated

continually.

Where OCTAVE fits

The book places the two together: when risk analysis is carried out using **OCTAVE**, that activity fits into the **Plan** phase of PDCA. The remaining phases deal with the necessary follow-up of the analysis, to see what to do next.

3.14 Worked examples

The book works three threat scenarios through both matrices. Reading them once shows how the ordinal scale behaves in practice.

The three scenarios

Threat	Frequency	Consequences	Risk
1	medium about once a month	high data for some employees is missing, giving legal problems and possibly compensation	$\text{medium} \times \text{high} = \text{medium}$
2	low about once a year	high loss of communication with the outside world, causing loss of income	$\text{low} \times \text{high} = \text{low}$
3	medium about once a month	high the design department cannot operate; loss of income and reputation	$\text{medium} \times \text{high} = \text{medium}$

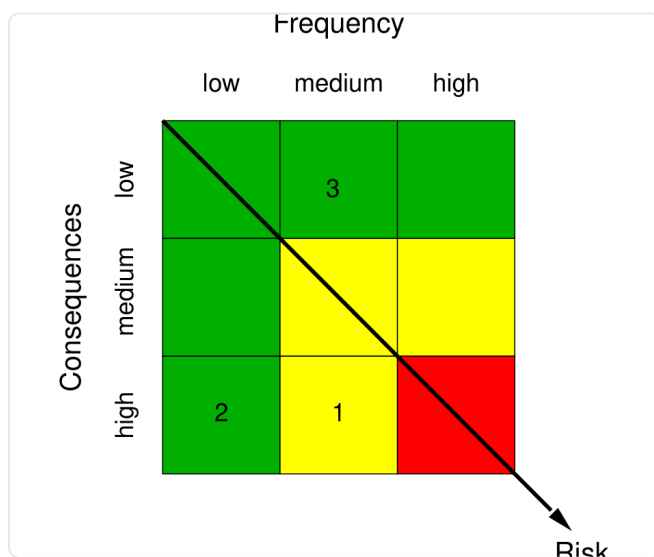


Figure 3.9 — the three threats placed in the risk matrix. (Sharp, p. 52)

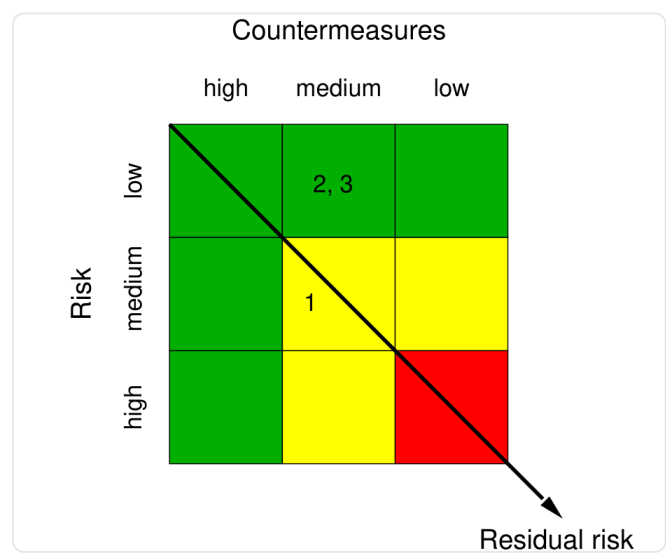


Figure 3.10 — the same threats after countermeasures. (Sharp, p. 53)

Then the countermeasures are applied

Threat	Risk	Countermeasures	Residual risk
1	medium	medium — backup of personnel records taken every night	medium / medium = medium
2	low	medium — spare mail server operational within 12 hours	low / medium = low
3	medium	medium — incremental backup of design files every hour	medium / medium = medium

WHAT THESE EXAMPLES PROVE ABOUT THE EQUATIONS

medium × high is given as medium, not as a number. So the multiplication and division are ordinal combinations read off the colour table — not arithmetic. See §3.5.

What happens next, in the book's own words

"After this one would typically consider whether the residual risk is too high — that is to say, whether it lies in a yellow or red area in the residual risk matrix. If the residual risk is too high, more or better countermeasures must be introduced, or other forms of risk mitigation must be used."

4.1 Security policy and access control

SOURCE

Everything from §4.1 onward comes from the **second, unidentified source** in the doctor's booklet. None of it appears in Sharp. The wording is reproduced as given, with one correction flagged in §4.4.

SECURITY POLICY

A **security policy** is documentation stating **how security should be implemented at each level**.

Businesses and organisations develop comprehensive security policies that define **who is authorised to access different assets** and **what they are allowed to do with those assets** when they do access them.

It is described as a **key component that brings all three levels of security together**.

Why free movement is a problem

The material's worked example: allowing employees and visitors **free access to all departments** creates a variety of security risks. Access control is needed for two distinct reasons:

1. To reduce **the human nature of temptation** — if everyone can move freely, it is much harder to stop them accessing or taking physical or cyber assets.
2. To **prevent accidents**.

THE POLICY-TO-ENFORCEMENT CHAIN

1. Develop a **cohesive access-control policy at each level** — giving authorised people appropriate levels of access to selected assets, while inhibiting access by people who are not authorised.
2. **Enforce** those policies with the correct **types and numbers** of access-control devices.

The devices named: **sensors · barriers · logs · ID badges · security guards** — as deemed appropriate.

Cyber security policy

The company's **cyber security policy** explains the **overall requirements** needed to protect an organisation's network data and computer systems.

THREE TERMS, IN INCREASING SCOPE

- **Security policy** — the document: *how* security is implemented at each level.
- **Cyber security policy** — the organisation's *overall requirements* for protecting network data and systems.
- **Cyber risk assessment and management** — the ongoing *process* (§4.8).

4.2 Locks, deadbolts and cipher locks

LOCKS AND KEYS — THE DISTINCTION WORTH QUOTING

The primary physical barrier in most security perimeters is the **lockable door**. The **door** provides the physical barrier, but in itself **it will only keep honest people out**. The **lock** provides the **authentication function** of the barrier, through its **key**. Having the key signifies that the person either **possesses or knows** the information required to gain access.

Standard key-locking deadbolts

- Locking mechanism similar to the electronic solenoid-operated deadbolt, but **engaged or withdrawn with a key**.
- Provide an added level of security for doors that **can be operated manually**.
- Available with a **single or double cylinder**.

Solenoid-operated deadbolt locks

- **Electronically operated** deadbolt locks.
- Offer an **increased level of security for the perimeter**.
- Adaptable to any security system; perform well as **auxiliary locks** on doors where access control is desired.

Cipher locks

- Require **personal access codes known by the user**.
- Often used in access-control and management systems.
- They operate by **unlocking magnetic door locks when the correct programmed code is entered** on the cipher-lock keypad.
- Provide an added level of security for **perimeter entry areas**.

THE THREE COMPARED IN ONE LINE EACH

Type	Distinguishing feature
Standard key-locking deadbolt	Operated by a key ; for doors operated manually; single or double cylinder
Solenoid-operated deadbolt	Electronic ; higher perimeter security; good as an auxiliary lock
Cipher lock	A personal access code entered on a keypad; releases a magnetic lock

THE SENTENCE THAT CARRIES THE MARKS

“The door provides the physical barrier but in itself will only keep honest people out.” It is a memorable line, and it makes the point that a barrier without an authentication function is not access control.

4.3 Gates and control relays

Access-control gates

Like a door, a **gate** is a type of physical barrier that can be **swung, drawn, or lowered** to control **ingress and egress** through a wall or fence. Two main types:

Type	Where it is used
Sliding gates	Used where high levels of operational safety and security are needed
Swinging gates	Equipped with fully adjustable hinges that allow the gate to swing through 180 degrees

Control relays

DEFINITION

Relays are **electromechanical devices** that employ safer, **low-voltage / low-current control signals** to control **higher-voltage / higher-current devices**.

The point of a relay in a security system is **safety of separation**: the thing the operator touches runs on low voltage and low current, while the thing being driven — a gate motor, a lock solenoid — can draw far more.

PHYSICAL SECURITY, IN THE ORDER THE MATERIAL PRESENTS IT

1. **Locks and keys** — the lockable door and the authentication function of the key
2. **Standard key-locking deadbolts** — key-operated
3. **Solenoid-operated deadbolt locks** — electronic
4. **Cipher locks** — code-operated
5. **Access-control gates** — sliding and swinging
6. **Control relays** — the low-voltage control layer

4.4 Authentication systems and the four factors

DEFINITION

Authentication is the process of **determining that someone is who they say they are**.

Effective access control involves being able to control the **ingress, egress and regress** to an asset based on **authorisation**. In particular, **limiting the access of unauthorised personnel to important assets is the most fundamental security step you can take**.

THE ONE-LINE LOGIC TO MEMORISE

Authorisation is based on authentication.

You cannot decide what someone may do until you know who they are. That single sentence makes the whole section answerable.

The four factors

MARKED RED BY THE DOCTOR — FOUR FACTORS, NOT THREE

Factor	The material's wording
Knowledge	Something you know — or something that only the designated person should know
Possession	Something you have — or something that only the designated person should have
Inheritance	Something you are — or something that only the designated person is
Location	Somewhere you are — or somewhere that only the designated person is

CORRECTED — ONE WORD IN THIS LIST IS WRONG

The material prints "**Inheritance**". The correct English term for *something you are* is **INHERENCE**. *Inheritance* means receiving property from a predecessor, which is unrelated. The word appears **nowhere in Sharp's book**, so this came in with the second source.

In the exam: her four words are Knowledge, Possession, Inheritance, Location — and the count of four is what she marked. If there is room, write "**inherence (something you are)**". It shows the correct term without contradicting her.

TWO MORE TRAPS IN THIS TABLE

- **There are four factors, not three.** Most students remember knowledge, possession and "something you are" — and drop **Location**.
- The standard security literature treats the **core** set as three (knowledge, possession, inherence) and **location** as an extension. So the material's four is defensible, but it is not the universal count.

4.5 Authentication technologies

Four physical technologies are described, in increasing order of data security.

Magnetic stripe readers

A magnetic stripe card is a physical credit-card-like device that contains authentication information in the form of **magnetically coded spots on a magnetic stripe**.

Smart cards

Also credit-card-like and often resembling magnetic stripe cards, but they offer **improved data security** due to the presence of **intelligent circuitry** that can be used to **hide the user's data until an authentication process has been performed**.

RFID badges

Radio Frequency Identification badges provide **hands-free** access-control tools that improve on the **bar code**, **magnetic stripe** and **proximity reader** technologies. The RFID system employs **radio signals** to identify unique items using an **RFID reader device** and **RFID tags**.

Biometric scanners

Biometrics is the term used to describe access-control mechanisms that use **human physical characteristics** to verify individual identities.

THE FOUR COMPARED

Technology	Its distinguishing feature
Magnetic stripe	Authentication data as magnetically coded spots on a stripe
Smart card	Intelligent circuitry hides the user's data until authentication succeeds — the reason it is more secure
RFID badge	Hands-free ; radio signals; improves on bar code, magnetic stripe and proximity readers
Biometric	Verifies identity from human physical characteristics

LIKELY QUESTION

Why is a smart card more secure than a magnetic stripe card? Because of the **intelligent circuitry** that conceals the user's data **until the authentication process has been carried out**. A stripe simply stores the data and gives it up on read.

4.6 Remote monitoring and automated access control

Remote-access monitoring

DEFINITION

Monitoring or measuring devices **from a remote location or control room**. In the security realm, this involves having **external access to the security system through a communication system**.

Automated access-control systems

These add another dimension to standard security monitoring and reporting. Note the qualification the material makes: automated access control is **not an integral part** of the typical intrusion-detection and monitoring system — but it **adds to the safety and convenience** of perimeter-access control.

They come in two flavours:

Type	What it does
------	--------------

Remote-access-control systems	Manages entry to protected areas by authenticating the identity of persons entering a secured area — a security zone or computer system — using an authentication system located in a different location than the access point
Remote-control access systems	Works with remote monitoring systems to monitor, control and supervise doors, gates and conveyances from a distance

THREE SIMILAR NAMES — KEEP THEM APART

Term	The key idea
Remote-access monitoring	Watching and measuring devices from a remote location or control room
Remote-access control	Managing entry by authenticating from a different location than the access point
Remote-control access	Operating doors, gates and conveyances at a distance, together with remote monitoring

EXAM TRAP

The three names differ only in word order. Read the question carefully: **monitoring** = observe · **remote-access control** = authenticate remotely · **remote-control access** = operate remotely.

4.7 The NIST material

READ ONCE AND MOVE ON — THIS SECTION CARRIES NO MARKING

These two blocks have **no highlight and no colour** in the doctor's copy, and the student's own assessment was that they are **not important**. They are recorded here for completeness only.

Develop a risk-management program

- Determine the risks of **losing control of a host**.
- Identify potential adversarial activities that could target your domain — for example, are they targeting **intellectual property**?
- Present a **risk-informed report** so the organisation recognises the risks and provides support and buy-in to resolve, reduce or prevent risks of loss.

Use NIST security controls

- Create a **matrix of individual concerns and associated attack vectors**.
- Provide **mitigation method(s)** for each.
- Select the appropriate **NIST family** — **Management, Operational, Technical** — of security controls to be implemented, referencing **NIST SP 800-53**.

- Ensure the reasons for selection are **commensurate to the risks**. The selection of low-, medium- and high-level implementations should be described in the guidance and should help ensure a **cost-effective** solution.
- “Don't overprescribe controls!”

The NIST Framework stakeholders — create a policy for assessments

- Define the environment.
- Determine organisational priorities for protecting company property and materials.
- Ensure senior management is supportive.
- Procedurally define a process and diligence to form an informative assessment outcome.

IF IT DOES COME UP, THE TWO FACTS WORTH HAVING

- The three NIST control families: **Management · Operational · Technical**.
- The reference for the controls: **NIST SP 800-53**.

4.8 Cyber risk assessment and management

DEFINITION

Cyber risk assessment and management is the process of **identifying, evaluating and mitigating** the risks associated with cyber threats to an organisation or system. It involves understanding the **potential vulnerabilities in a system**, the **likelihood of cyberattacks**, and the **impact** such attacks could have on the organisation's **operations, reputation and data security**.

The four key components — in order

LEARN THE SEQUENCE

#	Component	What it involves
1	Risk Identification	Pinpointing potential cyber threats — malware, phishing, ransomware, data breaches, and so on
2	Risk Evaluation	Analysing the likelihood of each risk materialising and the severity of its potential impact
3	Risk Mitigation	Developing strategies to reduce or manage the risks — implementing controls such as firewalls, encryption, user education and backup systems
4	Monitoring and Review	Continuously observing the cyber landscape, updating defences, and reassessing risks as new threats emerge

Why it matters

- As technology advances, cyber threats become more complex, making risk management essential for **protecting sensitive data** and ensuring the **continuity of business operations**.
- Standards and frameworks such as **ISO 27001**, the **NIST Cybersecurity Framework**, and country-specific guidelines — for example from the **UK's National Cyber Security Centre** — provide structured approaches.

The outcome: by properly conducting cyber risk assessments and management, organisations can **improve their resilience against attacks** and better prepare for the inevitable challenges of the digital landscape.

NOTE THE OVERLAP WITH §3.9

Component 3, **Risk Mitigation**, is the same idea as the risk mitigation of §3.9 — the part of risk management aiming to reduce risk to an acceptable level. Here it is given the concrete controls: firewalls, encryption, user education, backups.

5 Exam traps and formula card

Formula card

Equation	Meaning	Symbols
$S = F \times K$	Basic risk of a threat	S basic risk · F frequency of attempts to exploit the vulnerability · K consequences of a successful attempt
$R = S / M$	Residual risk after countermeasures	R residual risk · S risk of the threat · M level of countermeasures — number AND effectiveness

HOW TO USE THEM

The scale is **ordinal** (low / medium / high), and the book's own examples print "**medium × high = medium**". So read the answer off **Figure 3.2** or **Figure 3.3** — do not multiply the words as numbers.

The numbers to remember

Count	What
2	Equations
4	Threat groups — hardware · software · data · liveware
5	Risk mitigation strategies — avoidance · reduction · retention · transfer · sharing
5	Analysis frameworks — COBIT · COSO · FAIR · ISO/IEC 27002 · OCTAVE
5	Steps for dealing with damage — preventing · complicating · diverting · detecting · reestablishing
14	ISO/IEC 27002 categories (the 2013 structure; 2022 is 4 themes / 93 controls)
3	OCTAVE phases
4	OCTAVE variants as listed in the book (3 exist publicly)
4	PDCA elements — plan · do · check · act
4	Authentication factors — knowledge · possession · inheritance/inherence · location
4	Cyber risk assessment components — identification · evaluation · mitigation · monitoring

Traps, in the order you will meet them

1. Fuzzification is input, defuzzification is output — carry-over from Week 01.
2. A threat is not a vulnerability. Weakness alone = vulnerability. Actor alone = threat.
3. Multiplication, not addition. Both factors must matter.

4. **Red has exactly one cell in each matrix.** (high, high) for risk; (high risk, low countermeasures) for residual risk.
5. **Do not mix the two matrices.** Risk matrix: frequency × consequences. Residual risk matrix: risk ÷ countermeasures.
6. **M is number AND effectiveness** — not just a count.
7. **The two five-item lists are different.** Dealing with damage (preventing...reestablishing) versus mitigation strategies (avoidance...sharing).
8. **Proactive 1–2–3, reactive 4–5** in the damage list.
9. **Act restarts PDCA** — it is a cycle, not a line.
10. **OCTAVE phases = 3; OCTAVE variants = 4 in the book.**
11. **14 categories** — and know that they are the 2013 structure.
12. **Authentication factors = 4**, and the third is *inherence*, not *inheritance*.
13. **Authorisation is based on authentication.**
14. **Insider threats are met with administrative controls** — vetting and training, not technology.
15. **Three remote terms differ by word order** — monitoring · remote-access control · remote-control access.

6 Glossary

Term	Meaning
Risk (technical sense)	The quantitative probability that an error situation occurs and gives rise to damage. Damage = a breach of the security policy
Objective risk	Risk as a property of the system, independent of opinion
Subjective risk	Risk as perceived, shaped by attitudes, trust and personality
Threat	An actor or event that can realise damage against a weakness
Vulnerability	A weakness which can be exploited to damage the system
Damage	A breach of the security policy
Basic risk (S)	Frequency of attempts × consequences of a successful attempt
Residual risk (R)	The risk remaining after countermeasures; risk divided by the level of countermeasures
Countermeasure / control (M)	A measure protecting against a threat. Covers number and effectiveness
Risk matrix	Grid placing threats by frequency and consequences
Residual risk matrix	Grid placing threats by risk and level of countermeasures
Inference	Deducing confidential information from data that is accessible
Masquerading	Pretending to be someone else
Liveware-related threat	A threat from human error among the computer's users
Malware	Viruses, worms, trojan horses, logic bombs
Risk management	All activities related to evaluating and reducing risks
Risk mitigation	The part of risk management aiming to reduce risk to an acceptable level
PDCA	Plan · Do · Check · Act — the cyclic form risk management takes
Authentication	Determining that someone is who they say they are
Authorisation	What an authenticated party is permitted to do. Based on authentication
Ingress / egress / regress	Entry / exit / return
Inherence	Something you are. Printed as “inheritance” in the material
Biometrics	Access control using human physical characteristics

7 Sources and verification notes

Primary source

CITATION

[Sharp, R., "Risk", in *Introduction to Cybersecurity: A Multidisciplinary Challenge*, Undergraduate Topics in Computer Science, Springer, Cham, 2023, pp. 37–56](https://doi.org/10.1007/978-3-031-41463-3_3)

Whole book: [Sharp, R., *Introduction to Cybersecurity: A Multidisciplinary Challenge*, Springer, Cham, 2023, 442 pp.] (<https://doi.org/10.1007/978-3-031-41463-3>) · ISBN 978-3-031-41463-3

Second source

Not identified. The physical-security, authentication and NIST material (§4.1–4.8) does not appear anywhere in Sharp's 452 pages. Four targeted searches failed to find it; its text is not publicly indexed. One term in it — *inheritance* — is not used by any published source for "something you are".

What was verified, and how

Claim	Verdict	Basis
$S = F \times K$	confirmed	Read verbatim from Sharp p. 38
$R = S / M$, with M = number + effectiveness	confirmed	Read verbatim from Sharp p. 39
The five mitigation strategies, in order	confirmed	Sharp p. 42, Definition 3.1
The three OCTAVE phases	confirmed	Sharp p. 46; matches the published OCTAVE method
PDCA, four elements	confirmed	Sharp p. 53
The four threat groups, including "liveware"	confirmed	Sharp p. 40
"ISO/IEC 27002 from 2022 ... 14 categories"	wrong	The 14 categories are the 2013 structure (114 controls in 14 clauses). 2022 is 4 themes / 93 controls . The sentence is Sharp's own, p. 45 — the booklet reproduces it faithfully
"OCTAVE FORTE" as a fourth variant	book only	Present in Sharp p. 46 with no description and a garbled sentence. No public OCTAVE source names it — only three methodologies are documented
Authentication factor " Inheritance "	wrong term	The standard term is Inherence . The word appears nowhere in Sharp

OCTAVE developed "for CERT"	imprecise	Developed at Carnegie Mellon University in 2001 for the US Department of Defense ; CERT/SEI is the CMU body
-----------------------------	-----------	--

Figures

All figures are the book's own, extracted from its typeset PDF: 3.1 (p. 38), 3.2 (p. 38), 3.3 (p. 39), 3.9 (p. 52), 3.10 (p. 53), 3.11 (p. 54). The Word booklet the doctor distributed contains **no images at all**, so none of these were available in it.

Figure 3.1 photograph: Terry Goss, Wikimedia Commons, file *White_shark.jpg*, licence **CC-BY 2.5 Generic**. Attribution required on reuse.

Content recovered from the book that the Word booklet had dropped

- The **five-step list for dealing with damaging events** (§3.8)
- The **security / functionality / usability** balance (§3.9)
- The **Danish 2009 survey** on objective versus subjective risk (§3.1)
- The book's **Table 3.1**, distinguishing ISO/IEC 27001 from 27002 (§3.11)
- All figures and both worked-example matrices (§3.14)

Booklet built 2026-09-23. English only, per the student's instruction. Every claim traced to a named source; nothing asserted without one. Where the source is wrong, the error is stated rather than silently corrected.